AVANT-PROPOS

La sécurité est un élément essentiel de la protection des données personnelles. Elle s'impose à tout responsable de traitement et sous-traitant à travers l'article 32 du règlement général sur la protection des données[1] (RGPD). En principe, chaque traitement doit faire l'objet d'un ensemble de mesures de sécurité décidées en fonction du contexte, à savoir « ***des précautions utiles, au regard de la nature des données et des risques*** *présentés par le traitement* » (article 121 de la loi Informatique et Libertés[2]). Le RGPD précise que la protection des données personnelles nécessite de prendre les « *mesures techniques et organisationnelles appropriées afin de garantir un* ***niveau de sécurité adapté au risque*** » pour les droits et libertés des personnes physiques, notamment leur vie privée.

Pour évaluer les mesures à mettre en place, deux approches complémentaires sont à déployer :

- **la mise en place d'un socle de sécurité** reprenant les bonnes pratiques issues d'années de capitalisation d'hygiène et de sécurité informatique (ex. : règlementations, normes, guides). Ce socle vise à répondre aux risques les plus courants ;
- **l'analyse des risques[3] pour les personnes** concernées par le traitement qui vise à identifier et évaluer les risques spécifiques au traitement. Une telle analyse permet d'étayer la prise de décision objective sur le traitement de ces risques et la détermination de mesures nécessaires et adaptées au contexte.

Il est cependant difficile, pour les non-spécialistes de la sécurité informatique, de mettre en œuvre une telle démarche et de s'assurer que le niveau de sécurité des traitements dont ils sont responsables est suffisant.

Pour aider dans la mise en conformité, ce guide présente un ensemble de préconisations regroupées par fiches thématiques. Chaque fiche est structurée en trois sections :

- les **précautions élémentaires**, qui reprennent les bonnes pratiques essentielles ;
- les **mauvaises pratiques tendancielles**, qui devraient être évitées ;
- les **mesures complémentaires**, pour aller plus loin[4].

Chaque fiche peut être lue séparément des autres : des renvois sont indiqués quand une autre fiche apporte plus de précisions sur un élément.

1 « Le règlement général sur la protection des données - RGPD », cnil.fr

2 « La loi Informatique et Libertés », cnil.fr

3 Elle est en particulier indispensable lorsque le traitement doit faire l'objet d'une analyse d'impact relative à la protection des données ou AIPD (voir « Ce qu'il faut savoir sur l'analyse d'impact relative à la protection des données (AIPD) », cnil.fr).

4 Ces mesures pourront avec le temps et la pratique devenir des précautions élémentaires.